Informe de seguridad

Portal de Reclamaciones | Versión de entrega | 27 de octubre de 2026

1. Resumen, autenticación y autorización

Se verificaron controles básicos de JWT, autorización por rol, rechazo de solicitudes sin token y registro de auditoría. Este documento describe el entorno local de evaluación; no es una auditoría independiente ni una certificación.

NOTA Resultados de smoke test: GET /v3/api-docs sin JWT = HTTP 200; GET /api/casos sin JWT = HTTP 401; el intento de ANALISTA de confirmar lote fue rechazado con HTTP 403.

Autenticación y sesión

- POST /api/auth/login permite enviar credenciales y entrega JWT a usuarios válidos.
- Las rutas protegidas reciben Authorization: Bearer <token>; Spring Security valida el JWT en cada petición.
- NoOpServerSecurityContextRepository evita mantener sesión de servidor. HTTP Basic, login estándar, logout estándar y CSRF están desactivados para el modelo Bearer previsto. Si se usan cookies, reevaluar CSRF.
- La validación usa HS256. app.jwt.secret se alimenta de configuración externa JWT_SECRET; la clave Base64 debe decodificar al menos 32 bytes.
- No se confirmó expiración exacta, renovación, revocación ni rotación del token; no asumir estos controles sin prueba.

Autorización observada

Operación	Regla
POST /api/auth/login	Pública.
Swagger UI y /v3/api-docs	Públicos en el perfil de evaluación.
PUT /api/parametros/**	SCOPE_ADMIN.
PATCH /api/lotes/{id}/pagar	SCOPE_ADMIN.
POST /api/casos/{codigo}/tomar	SCOPE_ANALISTA.
POST /api/lotes	SCOPE_ANALISTA o SCOPE_ADMIN.
Resto de rutas	Autenticación salvo excepciones.
Decisión de caso	JWT más validación de estado/asignación/observación.

2. Datos, auditoría y pruebas

Protección de datos y trazabilidad

- El listado de casos enmascara documentos; el detalle autenticado puede mostrar el dato completo según el caso de uso.
- Se observaron eventos de auditoría/seguimiento para cambios de parámetros, toma y decisión de caso, y creación/confirmación de lote.
- La observación de decisión valida longitud mínima. La observación breve probada fue rechazada con HTTP 400 y no modificó el estado del caso.
- La exportación CSV se comprobó con 60 filas y ocho encabezados. En la revisión realizada no hubo fórmulas peligrosas sin neutralizar; repetir ante cambios del exportador.
- La prueba de festivos simula API inaccesible y caché vacía; verifica SIN_FESTIVOS_VALIDOS, alerta ANS y evento FALLO_API_FESTIVOS usando repositorios simulados.
- El lote comprobado es un pago simulado, sin transferencia monetaria real.

Evidencias ejecutadas

Verificación	Resultado
mvnw clean verify	BUILD SUCCESS; 2 pruebas, 0 fallos/errores.
OpenAPI sin token	HTTP 200.
GET /api/casos sin token	HTTP 401.
ANALISTA confirma lote	HTTP 403.
ADMIN confirma lote simulado	Flujo completado y auditoría registrada.
Observación muy breve	HTTP 400; sin transición por esa petición.
API festivos sin caché	Resultado no validado y auditoría simulada.
CSV	60 filas y 8 columnas; no se detectó fórmula sin neutralizar.

Exposición de Swagger

Swagger UI /swagger-ui.html y OpenAPI /v3/api-docs son públicos en el perfil actual, lo que facilita la evaluación pero revela la estructura de la API. El smoke test confirma que /api/casos permanece protegido. En producción, deshabilitar la documentación por perfil o restringirla por rol/red.

3. Riesgos residuales y recomendaciones

Tema	Acción recomendada antes de producción
Ciclo de vida JWT	Documentar/probar vencimiento, renovación, revocación, rotación de clave y compromiso.
Intentos de acceso	Verificar rate limit o bloqueo progresivo y alertas sobre fallos repetidos de login.
Transporte y secretos	Usar HTTPS, no guardar secretos en repositorio, limitar acceso y rotar claves.
CORS y encabezados	Definir orígenes, métodos y encabezados permitidos para el despliegue.
Autorización por objeto	Agregar pruebas negativas por rol y validar permisos en cada detalle.
Auditoría y datos	Definir retención, acceso a auditoría y minimización en listado/exportación.
Continuidad	Definir copias y recuperación de PostgreSQL y monitoreo de errores.
Pruebas adicionales	Cubrir firma inválida/expiración JWT, permisos, fórmulas CSV, concurrencia de lotes y festivos con/sin caché.

Conclusión

En el entorno local ensayado funcionan los controles básicos: los recursos de negocio requieren JWT, el pago simulado está restringido a ADMIN, los flujos principales generan trazabilidad y el fallo de festivos se comunica sin inventar fechas. Los temas de esta sección son pendientes de endurecimiento, no controles demostrados. Repetir validaciones con la configuración real del despliegue.